

Pentest Rapport

Hvorfor skriver vi en rapport

- Vise hvad I har fundet
- Forklare hvordan I har fundet det
- Hjælpe med at gøre det nemt at fikse fejlene

Hvem skal læse rapporten

Chefer/Executives

- Vil vide: *Er vores system i fare - og hvor slemt er det for forretningen*
- Klare, simple “Executive summaries”
- Forstår ikke tekniske detaljer

Skrivemåde

- Normalt sprog - ikke teknisk
- BLUF - Bottom Line Up Front
 - Start med det vigtigste
- Skal kunne orientere sig ved at læse første side af rapporten - hvis ikke mindre

Udviklere/IT medarbejdere

- Vil vide: *Hvad præcist er i stykker og hvordan kan vi fikse det.*
- Har brug for tekniske detaljer
- Forstår værktøjer, kode og risiko

Skrivemåde

- Vær præcise og detaljerede

Eksempel på rapport struktur

- Cover page/Forside
- Executive summary/Resumé
- Scope
- Findings/Resultater
- Recommendations/Anbefalinger
- Appendix/Bilag

Cover page/Forside

- Navn på rapporten
- Jeres navn(e) og dato
- Målet - *hvilket system er rapporten om*
 - Evt. versionen

Executive Summary/Resumé

- Hvad blev testet
- Oversigt over findings
- Helt overordnet - **hvor cooked er de**

Scope

- Hvad er blevet testet
- Hvilke tools er blevet brugt
- Hvor meget tid har i brugt
- Regler og restriktioner på testen

Findings/Resultater

Et under afsnit for hver finding

- Navn på finding
- Severity - Hvor slemt er det
- Kort beskrivelse
- Teknisk beskrivelse
- Anbefalinger

Recommendations/Anbefalinger

- Generelle anbefalinger som ikke kom med som problemer
- Kan være
 - Brug HTTPS
 - Husk at opdatere X
 - Osv.

Appendix/Bilag

- Screenshots
- Større logs/kommandoer
- Generelt ting som ville fylde for meget i selve rapporten

Slides

Slides kan findes på <https://tmp.dnorhoj.me/slides.pdf>